

Reporte Ejecutivo de Gestión de Riesgos

Centro Médico del Valle · Clínica Privada
Preparado con SimpleRisk · Septiembre 2026

Resumen ejecutivo

A raíz de una auditoría externa reciente que identificó debilidades en la gestión de riesgos, se llevó a cabo un relevamiento integral utilizando la herramienta SimpleRisk. Se identificaron **9 riesgos** específicos para la operación de la clínica (120 empleados, ~800 pacientes/día), abarcando amenazas técnicas (ransomware, exfiltración de datos), factores humanos (phishing) y debilidades organizativas (backups, gestión de accesos, cumplimiento normativo). Se definieron **3 planes de acción prioritarios** para mitigar los riesgos de mayor severidad, con responsables, plazos y presupuesto estimado asignados.

Distribución de riesgos por nivel

Nivel	Cantidad	Riesgos
Alto (High)	1	R01 · Ransomware sobre historias clínicas
Medio (Medium)	6	R02, R03, R04, R05, R06, R07
Bajo (Low)	2	R08, R09

Nota metodológica: el análisis documentado por el equipo (ver informe técnico, Anexo) clasifica los riesgos en una escala 1-25 (Crítico/Alto/Medio/Bajo) basada en probabilidad e impacto justificados con evidencia del sector (Verizon DBIR). SimpleRisk aplica su propio método de puntuación ponderado ("Classic"), cuyos resultados (arriba) son consistentes en la priorización: el riesgo de ransomware es, en ambos esquemas, el de mayor severidad.

Top 5 riesgos por nivel de severidad

ID	Riesgo	Riesgo Inherente	Nivel
R01	Ransomware sobre servidores de historias clínicas	8.0	High
R03	Phishing dirigido al personal administrativo	6.4	Medium
R02	Exfiltración de datos de pacientes (PHI)	6.0	Medium
R04	Ausencia de backups probados y plan de recuperación	6.0	Medium
R05	Accesos con privilegios excesivos y cuentas compartidas	4.8	Medium

Estado de los planes de acción

Plan	Riesgo asociado	Responsable	Vencimiento	Avance
PA-01	R01 - Ransomware	Gerencia de TI	90 días	0%
PA-02	R02 - Exfiltración de datos	Resp. de Seguridad	120 días	0%
PA-03	R03 - Phishing / MFA	Resp. de Seguridad	60 días	25% (en curso)

Principales hallazgos

- El mayor riesgo es el **ransomware sobre los servidores de historias clínicas**, agravado por la ausencia de backups probados (R04): hoy un incidente de este tipo dejaría a la clínica sin capacidad de atención y sin forma de recuperar la información.
- El **phishing** (R03) es el vector de entrada más probable hacia los riesgos de mayor impacto, favorecido por la falta de capacitación formal y de autenticación multifactor.
- Existen **debilidades organizativas** (privilegios excesivos, cuentas compartidas, ausencia de política formal de datos personales) que, si bien no son las de mayor puntaje individual, aumentan la probabilidad e impacto de los demás riesgos.

Recomendaciones prioritarias para la Dirección

1. Aprobar y financiar el Plan PA-01 (defensa contra ransomware)

Es la inversión de mayor impacto: reduce el riesgo más severo identificado. Presupuesto estimado: USD 12.000.

2. Implementar backups probados con restauración periódica (R04)

Complemento indispensable de PA-01: sin backups verificados, cualquier incidente grave implica pérdida irreversible de historias clínicas.

3. Priorizar el despliegue de MFA y la capacitación anti-phishing (PA-03)

Es la medida de menor costo relativo (USD 4.000) con mayor efecto en reducir la probabilidad de incidentes, dado que el factor humano es la puerta de entrada más común.

4. Revisar la política de accesos (R05) y las interfaces con obras sociales (R06)

Acciones de bajo costo (ajustes de configuración y procesos) que reducen significativamente la superficie de exposición.

5. Iniciar un programa formal de cumplimiento de la Ley 25.326 (R07)

Designar un responsable de protección de datos y documentar las medidas de seguridad exigidas para datos de salud, dado que la clínica maneja datos sensibles a diario.

Próximos pasos

Se solicita a la Dirección la aprobación del presupuesto conjunto de los 3 planes de acción (USD 24.000 estimados) y la designación formal de los responsables mencionados. El seguimiento del avance se realizará mensualmente en SimpleRisk, con reportes de estado a esta Dirección cada 30 días.

Documento preparado a partir del registro de riesgos cargado en SimpleRisk como parte del Trabajo Práctico de la cátedra Seguridad de Sistemas. Ver informe técnico completo (informe/informe.md) para el detalle metodológico y la justificación de cada riesgo.